

CYBERSECURITY PORTFOLIO

HANDS-ON LAB · VULNERABILITY MANAGEMENT



Windows Vulnerability Assessment

Carter Yanosick

Portfolio Edition

SANITIZED COPY

Original technical content and evidence preserved.
Other participant names removed for public portfolio use.

Part 1: Network Discovery and Enumeration

1) Private IP: 10.10.10.5 (confirmed/incorrect)

2)

```
(student02@kali)-[~]  
$ nmap -sn 10.10.10.0/24  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 19:43 +0000  
Nmap scan report for _gateway (10.10.10.1)  
Host is up (0.00033s latency).  
MAC Address: 12:34:56:78:9A:BC (Unknown)  
Nmap scan report for 10.10.10.4  
Host is up (0.00052s latency).  
MAC Address: 12:34:56:78:9A:BC (Unknown)  
Nmap scan report for 10.10.10.6  
Host is up (0.00044s latency).  
MAC Address: 12:34:56:78:9A:BC (Unknown)  
Nmap scan report for kali.local (10.10.10.5)  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.00 seconds
```

Discovering live hosts on lab subnet

3)

```
(student02@kali)-[~]  
$ nmap -sV -sC -p- 10.10.20.4 -oN scan_results.txt  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 19:51 +0000  
Nmap scan report for victim.internal.cloudapp.net (10.10.20.4)  
Host is up (0.0013s latency).  
Not shown: 65518 filtered tcp ports (no-response)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          FileZilla ftpd 1.12.6  
|_ftp-anon: got code 503 "Use AUTH first."  
|_tls-alpn:  
|_ftp  
|_ssl-cert: Subject: commonName=filezilla-server self signed certificate  
|_Not valid before: 2026-07-29T20:30:04  
|_Not valid after: 2027-07-30T20:35:04  
|_ftp-syst:  
|_SYST: UNIX emulated by FileZilla.  
80/tcp    open  http         Microsoft IIS httpd 10.0
```

Run full port and service/version scan against the victim machine

4)

Port	Service	Version	Notes
21	FTP	FileZilla FTP Server 1.12.6	Anonymous login disabled (AUTH required), self-signed certificate
80	HTTP	Microsoft IIS 10.0	TRACE method enabled
135	MSRPC	Microsoft Windows RPC	Windows RPC endpoint
139	NetBIOS	Microsoft NetBIOS Session Service	SMB-related service
445	Microsoft-DS (SMB)	Windows SMB	SMB signing enabled but not required
1433	Microsoft SQL Server	SQL Server 2019 RTM (15.00.2000.00)	No service pack installed
3389	RDP	Microsoft Terminal Services	Remote Desktop enabled
5985	WinRM	Microsoft HTTPAPI 2.0	Windows Remote Management
47001	WinRM	Microsoft HTTPAPI 2.0	WinRM management port
49664-49669	MSRPC	Windows RPC	Dynamic RPC ports
49671	MSRPC	Windows RPC	Dynamic RPC port
50766	MSRPC	Windows RPC	Dynamic RPC port

Recording of every open port, service, and version numbers made into digestible table (ChatGPT produced)

5) Search of known exploits that were pinged from the victims machine

<pre>(student02@kali) ~ \$ searchsploit "Microsoft SQL Server 2019"</pre>	
Exploit Title	Path
Microsoft Windows SQL Server - Remote Denial of Service (MS93-031)	windows/dos/65.c
Shellcodes: No Results	

Microsoft SQL server 2019

<pre>(student02@kali) ~ \$ searchsploit "Microsoft Terminal Services"</pre>	
Exploit Title	Path
Microsoft Terminal Services - Use-After-Free (MS12-020)	windows/dos/18606.txt
Shellcodes: No Results	

Microsoft terminal services

Continued...

Exploit Title	Path
CyberCop Scanner Smbgrind 5.5 - Buffer Overflow (PoC)	windows/dos/39452.txt
DOUBLEPULSAR - Payload Execution and Neutralization (Metasploit)	windows/remote/47456.rb
DOUBLEPULSAR - Payload Execution and Neutralization (Metasploit)	windows/remote/47456.rb
Microsoft - SMB Server Trans2 Zero Size Pool Alloc (MS10-054)	windows/dos/14607.py
Microsoft DNS RPC Service - 'extractQuotedChar()' Remote Overflow 'SMB' (MS07-029) (Metasploit)	windows/remote/16366.rb
Microsoft SMB Driver - Local Denial of Service	windows/dos/28001.c
Microsoft Windows - 'EternalRomance'/'EternalSynergy'/'EternalChampion' SMB Remote Code Execution (Metasploit) (	windows/remote/43970.rb
Microsoft Windows - 'SMB' Transaction Response Handling (MS05-011)	windows/dos/1065.c
Microsoft Windows - 'SMBGhost' Remote Code Execution	windows/remote/48537.py
Microsoft Windows - 'srv2.sys' SMB Code Execution (Python) (MS09-050)	windows/remote/40280.py
Microsoft Windows - 'srv2.sys' SMB Negotiate ProcessID Function Table Dereference (MS09-050)	windows/remote/14674.txt
Microsoft Windows - 'srv2.sys' SMB Negotiate ProcessID Function Table Dereference (MS09-050) (Metasploit)	windows/remote/16363.rb
Microsoft Windows - 'WRITE_ANDX' SMB Command Handling Kernel Denial of Service (Metasploit)	windows/dos/6463.rb
Microsoft Windows - LSASS SMB NTLM Exchange Null-Pointer Dereference (MS16-137)	windows/dos/40744.txt
Microsoft Windows - SMB Client-Side Bug (PoC) (MS10-006)	windows/dos/12258.py
Microsoft Windows - SMB Relay Code Execution (MS08-068) (Metasploit)	windows/remote/16360.rb
Microsoft Windows - SMB Remote Code Execution Scanner (MS17-010) (Metasploit)	windows/dos/41891.rb
Microsoft Windows - SMB2 Negotiate Protocol '0x72' Response Denial of Service	windows/dos/12524.py
Microsoft Windows - SmbRelay3 NTLM Replay (MS08-068)	windows/remote/7125.txt
Microsoft Windows 10 (1903/1909) - 'SMBGhost' SMB3.1.1 'SMB2_COMPRESSION_CAPABILITIES' Buffer Overflow (PoC)	windows/dos/48216.md
Microsoft Windows 10 (1903/1909) - 'SMBGhost' SMB3.1.1 'SMB2_COMPRESSION_CAPABILITIES' Local Privilege Escalatio	windows/local/48267.txt
Microsoft Windows 10 - SMBv3 Tree Connect (PoC)	windows/dos/41222.py
Microsoft Windows 10.0.17134.648 - HTTP -> SMB NTLM Reflection Leads to Privilege Elevation	windows/local/47115.txt
Microsoft Windows 2000/XP - SMB Authentication Remote Overflow	windows/remote/20.txt
Microsoft Windows 2003 SP2 - 'ERRATICGOPHER' SMB Remote Code Execution	windows/remote/41929.py
Microsoft Windows 2003 SP2 - 'RRAS' SMB Remote Code Execution	windows/remote/44616.py
Microsoft Windows 7/2008 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010)	windows/remote/442031.py
Microsoft Windows 7/2008 R2 - SMB Client Trans2 Stack Overflow (MS10-020) (PoC)	windows/dos/12273.py
Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010)	windows/remote/42315.py
Microsoft Windows 8.1/2012 R2 - SMBv3 Null Pointer Dereference Denial of Service	windows/dos/441189.py
Microsoft Windows 8/8.1/2012 R2 (x64) - 'EternalBlue' SMB Remote Code Execution (MS17-010)	windows_x86-64/remote/42030.py
Microsoft Windows 95/Windows for Workgroups - 'smbclient' Directory Traversal	windows/remote/20371.txt
Microsoft Windows NT 4.0 SP5 / Terminal Server 4.0 - 'Pass the Hash' with Modified SMB Client	windows/remote/19197.txt
Microsoft Windows Server 2008 R2 (x64) - 'SrvOs2FeaToNt' SMB Remote Code Execution (MS17-010)	windows_x86-64/remote/41987.py
Microsoft Windows SMB Server (v1/v2) - Mount Point Arbitrary Device Open Privilege Escalation	windows/dos/43517.txt
Microsoft Windows Vista/7 - SMB2.0 Negotiate Protocol Request Remote Blue Screen of Death (MS07-063)	windows/dos/9594.txt
Microsoft Windows XP/2000 - 'Mrxsmb.sys' Local Privilege Escalation (MS06-030)	windows/local/1911.c
Microsoft Windows XP/2000/NT 4.0 - Network Share Provider SMB Request Buffer Overflow (1)	windows/dos/21746.c
Microsoft Windows XP/2000/NT 4.0 - Network Share Provider SMB Request Buffer Overflow (2)	windows/dos/21747.txt
VideoLAN VLC Client (Windows x86) - 'smb://' URI Buffer Overflow (Metasploit)	windows_x86/local/16678.rb
VideoLAN VLC Media Player 0.8.6f - 'smb://' URI Handling Remote Buffer Overflow	windows/remote/9303.c
VideoLAN VLC Media Player 0.8.6f - 'smb://' URI Handling Remote Universal Buffer Overflow	windows/remote/9318.py
VideoLAN VLC Media Player 0.9.9 - 'smb://' URI Stack Buffer Overflow (PoC)	windows/dos/9029.rb
VideoLAN VLC Media Player 1.0.0/1.0.1 - 'smb://' URI Handling Buffer Overflow (PoC)	windows/dos/9427.py
VideoLAN VLC Media Player 1.0.2 - 'smb://' URI Stack Overflow	windows/remote/9816.py
VideoLAN VLC Media Player 1.0.3 - 'smb://' URI Handling Remote Stack Overflow (PoC)	windows/dos/10333.py
VideoLAN VLC Media Player < 1.1.4 - '.xspf smb://' URI Handling Remote Stack Overflow (PoC)	windows/dos/14892.py
WebExec - (Authenticated) User Code Execution (Metasploit)	windows/remote/45695.rb
WebExec - (Authenticated) User Code Execution (Metasploit)	windows/remote/45695.rb

Windows SMB

Part 2

1)

```

└─$ nmap -sV --script vuln 10.10.20.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 20:34 +0000
Nmap scan report for victim.internal.cloudapp.net (10.10.20.4)
Host is up (0.00096s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          FileZilla ftpd 1.12.6
80/tcp    open  http         Microsoft IIS httpd 10.0
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-server-header: Microsoft-IIS/10.0
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-enum:
|   /admin/: Possible admin folder
|   /admin/index.html: Possible admin folder
|   /Admin/: Possible admin folder
|_ /backup/: Possible backup
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
1433/tcp  open  ms-sql-s     Microsoft SQL Server 2019 15.00.2000
|_vulners:
|   cpe:/a:microsoft:sql_server:2019:
|   CVE-2023-38169 8.8 https://vulners.com/cve/CVE-2023-38169
|   CVE-2023-21713 8.8 https://vulners.com/cve/CVE-2023-21713
|   CVE-2023-21705 8.8 https://vulners.com/cve/CVE-2023-21705
|   CVE-2021-1636 8.8 https://vulners.com/cve/CVE-2021-1636
|   CVE-2023-36785 7.8 https://vulners.com/cve/CVE-2023-36785
|   CVE-2023-36730 7.8 https://vulners.com/cve/CVE-2023-36730
|   CVE-2023-36420 7.8 https://vulners.com/cve/CVE-2023-36420
|   CVE-2023-36417 7.8 https://vulners.com/cve/CVE-2023-36417
|   CVE-2023-32028 7.8 https://vulners.com/cve/CVE-2023-32028
|   CVE-2023-32027 7.8 https://vulners.com/cve/CVE-2023-32027
|   CVE-2023-32026 7.8 https://vulners.com/cve/CVE-2023-32026
|   CVE-2023-32025 7.8 https://vulners.com/cve/CVE-2023-32025
|   CVE-2023-29356 7.8 https://vulners.com/cve/CVE-2023-29356
|   CVE-2023-29349 7.8 https://vulners.com/cve/CVE-2023-29349
|   CVE-2023-21718 7.8 https://vulners.com/cve/CVE-2023-21718
|   CVE-2023-21704 7.8 https://vulners.com/cve/CVE-2023-21704
|   CVE-2023-21528 7.8 https://vulners.com/cve/CVE-2023-21528
|   CVE-2022-23276 7.8 https://vulners.com/cve/CVE-2022-23276
|   CVE-2022-29143 7.5 https://vulners.com/cve/CVE-2022-29143
|   CVE-2023-23384 7.3 https://vulners.com/cve/CVE-2023-23384
|_   CVE-2023-36728 5.5 https://vulners.com/cve/CVE-2023-36728
|_tls-ticketbleed: ERROR: Script execution failed (use -d to debug)
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.

```

Run nmap vulnerability detection script against the victim machine

2&3)

CVE-2023-38169:

Microsoft SQL OLE DB remote-code-execution vulnerability. A remote attacker could use specially crafted content to trigger code execution through a vulnerable OLE DB component, although user interaction is required. (Base score: 8.8 / Rank: High)

CVE-2023-21713:

Microsoft SQL Server remote-code-execution vulnerability involving unsafe deserialization. A network attacker with limited SQL privileges could potentially execute code on the server. (Base score: 8.8 / Rank: High)

CVE-2023-21705:

Microsoft SQL Server Remote Code Execution Vulnerability associated with the use of a hard-coded cryptographic key. Exploitation requires limited privileges but can occur across the network (Base score: 8.8 / Rank: High)

CVE-2021-1636:

Microsoft SQL Elevation of Privilege Vulnerability An authenticated network attacker could potentially gain higher privileges. (Base score: 8.8 / Rank: High)

CVE-2023-36785:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability It requires local processing and user interaction rather than a direct attack against TCP 1433 (Base score: 7.8 / Rank: Medium)

CVE-2023-36730:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability Exploitation requires a victim to process malicious content locally (Base score: 7.8 / Rank: Medium)

CVE-2023-36420:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability involving a double-free memory condition. It requires local access or user interaction (Base score: 7.8 / Rank: Medium)

CVE-2023-36417:

Microsoft SQL OLE DB Remote Code Execution Vulnerability involving a heap-based buffer overflow. A victim must process malicious content through the vulnerable component. (Base score: 7.8 / Rank: Medium)

CVE-2023-32028:

Microsoft SQL OLE DB Remote Code Execution Vulnerability The attack vector is local and requires user interaction, so an open SQL Server port alone does not expose it directly (Base score: 7.8 / Rank: Medium)

CVE-2023-32027:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability It requires locally processed malicious content and user interaction. (Base score: 7.8 / Rank: Medium)

CVE-2023-32026:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability Successful exploitation requires a user or application to process specially crafted content locally. (Base score 7.8 / Rank: Medium)

CVE-2023-32025:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability It is a local, user-interaction attack rather than a direct remote attack against the SQL service. (Base score: 7.8 / Rank: Medium)

CVE-2023-29356:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability A user must process or open specially crafted content through the vulnerable driver. (Base score: 7.8 / Rank: Medium)

CVE-2023-29349:

Microsoft ODBC and OLE DB Remote Code Execution Vulnerability It requires local processing and user interaction, limiting direct exposure through port 1433 (Base score: 7.8 / Rank: Medium)

CVE-2023-21718:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability Exploitation requires local access and user interaction with malicious content (Base score: 7.8 / Rank: Medium)

CVE-2023-21704:

Microsoft ODBC Driver for SQL Server Remote Code Execution Vulnerability The attacker requires local access and low-level privileges, but no additional user interaction is indicated. (Base score: 7.8 / Rank: Medium)

CVE-2023-21528:

Microsoft SQL Server Remote Code Execution Vulnerability It requires local access and an existing low-privileged account, reducing exposure from the open network port. (Base score: 7.8 / Rank: Medium)

CVE-2022-23276:

SQL Server for Linux Containers Elevation of Privilege Vulnerability scanned target is Windows Server rather than a Linux SQL container, this CVE does not appear applicable to this host (Base score: 7.8 / Rank: Low)

CVE-2022-29143:

Microsoft SQL Server Remote Code Execution Vulnerability A network attacker with limited SQL privileges could potentially exploit the server, although attack complexity is high. (Base score: 7.5 / Rank: Medium)

CVE-2023-23384:

Microsoft SQL Server Remote Code Execution Vulnerability It is network-accessible, requires no privileges or user interaction, and therefore deserves high priority when TCP 1433 is exposed. (Base score: 7.3 / Rank: High)

CVE-2023-36728:

Microsoft SQL Server Denial of Service Vulnerability A local, low-privileged attacker could cause the SQL Server service to become unavailable (Base score: 5.5 / Rank: Medium)

Part 4

CVE-2023-38169

Update any installed Microsoft OLE DB or ODBC drivers to current supported releases. Removing the older components replaces the vulnerable code that could permit remote code execution.

CVE-2023-21713

Restrict TCP port 1433 through the Azure Network Security Group and Windows Firewall so only approved application servers and database administrators can reach the service

CVE-2023-21705

Remove unnecessary SQL accounts or server-level permissions. This corrects the vulnerable SQL Server code and limits the ability of a low-privileged account to abuse the service.

CVE-2021-1636

Review SQL roles and remove unnecessary elevated permissions so an authenticated user cannot use the vulnerability to increase privileges.

CVE-2023-36785

Replace any affected Driver 17 or Driver 18 installation with a current supported release.

CVE-2023-36730

Update to a security-fixed supported release and uninstall the vulnerable older driver package. This replaces the defective driver code that could allow remote code execution when malicious content is processed

CVE-2023-36420

Removing outdated side-by-side driver installations prevents applications from continuing to use the vulnerable component.

CVE-2023-36417

Upgrade on the victim computer to a supported cumulative update or GDR containing the fix. Also verify whether Driver 18 or 19 is installed and update or remove it if affected

CVE-2023-32028

Replace any affected Driver 18 or Driver 19 release with a current supported version. This closes the gap by preventing applications from processing data through the vulnerable OLE DB library

CVE-2023-32027

Check the victim computer for Driver 17 versions below 17.10.4.1 or Driver 18 versions below 18.2.2.1. If an affected driver is installed, update it to a supported security-fixed release and remove unused older copies

CVE-2023-32026

Uninstalling the vulnerable package prevents database applications from loading and executing the flawed driver code.

CVE-2023-32025

Remove older driver versions after application testing so programs cannot continue selecting the vulnerable version

CVE-2023-29356

Update all installations to supported security-fixed versions. After confirming that the banking application works with the updated driver, decommission the affected older package.

CVE-2023-29349

Update both Microsoft ODBC and OLE DB Remote Code Execution Vulnerability, this vulnerability affects both data-access components. Remove unused legacy providers so no application can call the vulnerable libraries

CVE-2023-21718

This vulnerability affects both data-access components. Remove unused legacy providers so no application can call the vulnerable libraries

CVE-2023-21704

Apply least privilege to Windows service accounts so compromised low-privileged accounts cannot use the driver to execute code with greater impact.

CVE-2023-21528

Restrict TCP 1433 to approved application servers and an administrator jump host, reducing access to the vulnerable database service

CVE-2022-23276

First verify that no Linux SQL container is running. If one exists, replace its old image with a patched Microsoft SQL Server container image and place it on an isolated application subnet.

CVE-2022-29143

Allow TCP 1433 only from systems that require database access, limiting remote exposure

CVE-2023-23384

Restrict TCP 1433 and require encrypted SQL connections using a trusted TLS certificate to protect approved database traffic

CVE-2023-36728

Limit local access, restrict TCP 1433, and monitor the SQL Server service for unexpected stops or restarts to reduce availability risk

Reflection Questions:

- 1) What was the single easiest piece of information to find that would help an attacker, and why was it so exposed?

The easiest information to find was the list of open ports and running services on the Windows victim computer. A basic Nmap scan revealed services as well as some version information. This was exposed because the services were listening on the network and responding to unauthenticated scan requests. An attacker could use this information to decide which services to investigate for vulnerabilities.

- 2) If you were defending this host instead of attacking it, which one change would you make first, and why that one before the others?

Microsoft SQL Server 2019 from the original RTM version 15.00.2000.00 to a current supported security build. SQL Server was directly accessible on port 1433 and appeared to have no post-release patches applied, which increases the chance that known vulnerabilities may still exist. I would address this first because SQL Server may contain sensitive banking information and could have a greater business impact.

- 3) How would you explain the risk you found today, in plain language, to a non-technical bank manager?

The server is exposing several services that anyone on the same network can easily discover. Some of those services are outdated or configured less securely than they should be. We did not prove that the server could be fully compromised, but the current setup gives an attacker multiple places to begin. Updating software, restricting network access, and eliminating unneeded services will significantly lower the danger to financial systems and consumer data.